

SPLUNK AGENTIC OPS HACKATHON · SECURITY

SupplyGuard

Your CI/CD pipeline added a backdoor last Tuesday.
Splunk caught it — and blocked the build.

Agentic Ops

HEC · SPL · Threat Intel

MCP Server

Hosted Models

NIS2 Article 21

Manoj Mallick

THE PROBLEM

Attacks enter through the **build pipeline**

XZ Utils, SolarWinds, Log4Shell — all arrived the same way: a dependency that wasn't there before, or one that silently changed.

~0%

teams monitor it

Security watches network traffic. Almost nobody watches the dependency manifest in real time.

weeks

to audit by hand

A manual typosquat / CVE audit across repos takes weeks — pipelines ship hourly.

1 char

is all it takes

reqursts vs requests — one edit away from a backdoor.

The pipeline is a **net-new Splunk data source** — net-new detection, net-new compliance angle.

THE SOLUTION

An **agent** that guards every build

SupplyGuard ingests CI/CD events into Splunk, then closes the loop — it doesn't just flag risk, it **blocks the build**.



A CI lint step stops here

“Print a warning, exit 0.” The risky dependency still ships, and nobody correlates it across repos.

SupplyGuard keeps going

Triages with a Splunk hosted security model, maps cross-repo impact, and blocks the build — behind a human-approval gate.

HOW WE USE SPLUNK

Four Splunk capabilities, one loop

CAPABILITY	HOW SUPPLYGUARD USES IT	PRIZE
HEC	Ingestion of CI/CD events — manifests, lockfiles, build logs	Core
SPL + Threat Intel	CVE correlation via lookup, install-spike detection, NIS2 posture	Core
MCP Server	Agent reads index=cicd over MCP (run_splunk_query, handshake)	Best Use of MCP
Hosted Models	foundation-sec classifies typosquats + writes the NIS2 note	Best Use of Models

One project, eligible for the **Security** prize + **two bonus prizes** — plus a regulatory wedge (**NIS2 Article 21**).

PROOF — RUNNABLE IN 2 SECONDS

Build **blocked** before it shipped

The agent senses a real build that added a typosquat *and* a critical-CVE dependency:

```
SENSE · pulled 4 new/changed deps for payment-service#1247 via MCP
DETECT · reqursts[typosquat:HIGH], log4j-core[cve:CRITICAL]
INVESTIGATE · foundation-sec: HIGH confidence typosquat · impacts 3 repos
DECIDE · block_build (approval_required=True)
ACT · executed: Build #1247 BLOCKED. Offending: log4j-core, reqursts
LOG · decision → index=cicd (audit + NIS2 trail)
```

`python demo.py --auto` · zero network, air-gapped by default.

THE DETECTION

Real edit distance, real CVEs

Typosquatting is caught with a true Levenshtein distance against a trusted-package set — computed in Python, not faked in SPL.

TYPOSQUAT

d = 1

requursts → requests. Edit-distance 1 = HIGH-confidence squat.

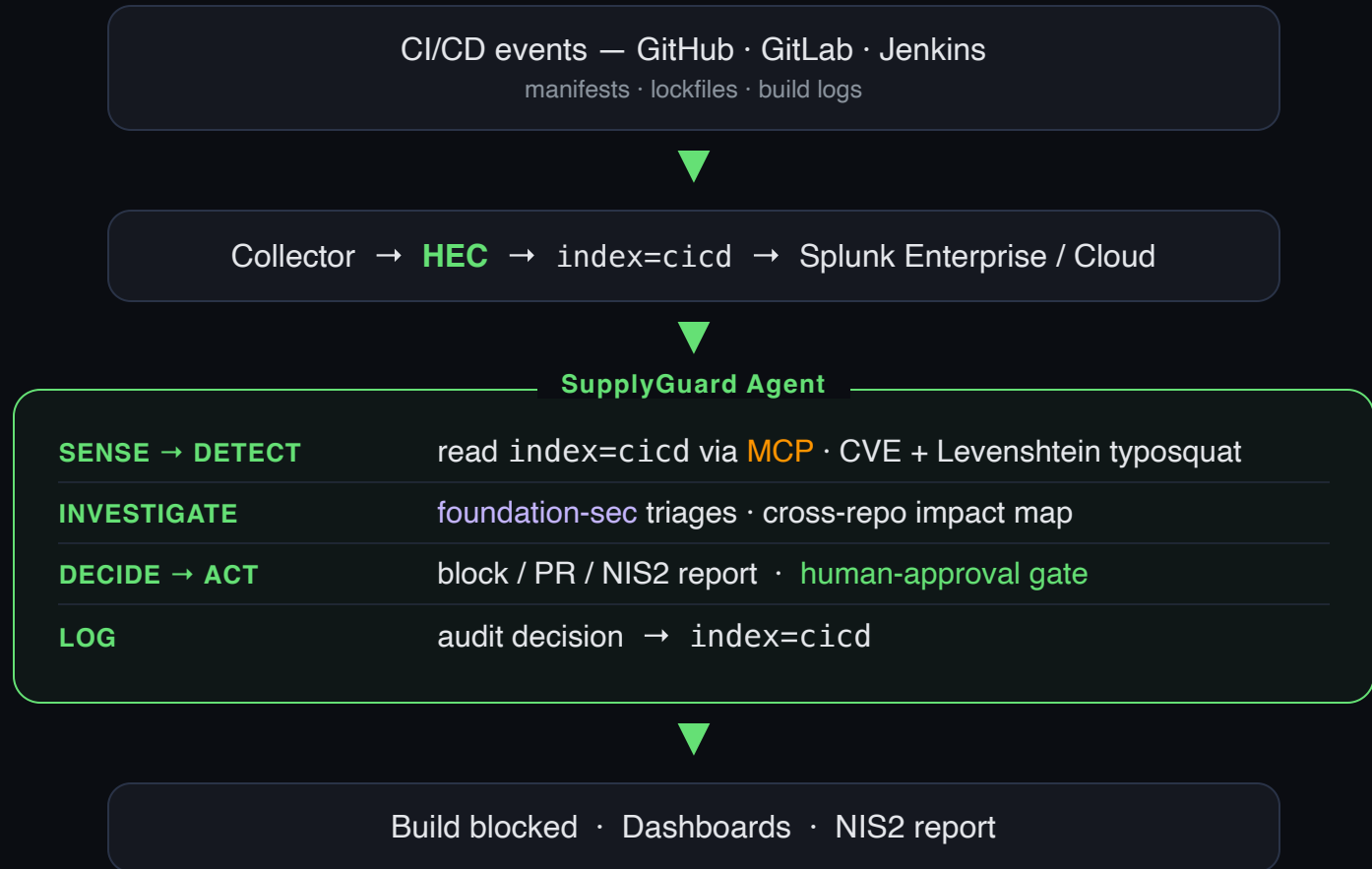
KNOWN CVE

9.0+

log4j-core 2.14 → CVE-2021-44228, CVSS 10.0. Auto-block threshold.

Deterministic evidence first; the hosted model adds judgment and the compliance narrative. No fabricated SPL functions, no join anti-pattern.

HEC in · agent loop · block out



WHY IT WINS

Judged on four criteria

Technological Implementation

Real HEC + MCP + hosted security model + a working control loop. Runs offline in 2 seconds; both gate-modes tested.

Quality of the Idea

The pipeline is a data source Splunk deployments don't monitor. Net-new detection, net-new compliance angle.

Potential Impact

Every org shipping software has this attack surface. Catches the squat/CVE before it reaches production.

Design

Enterprise SOC dashboard in Dashboard Studio — risk profile, detections, agent audit trail.

Agentic, not a lint step — it *blocks*, with responsible-autonomy safeguards.

It blocks — but it shows its work

Approval gate

A hard build-block waits for one human click unless explicitly autonomous.

NIS2 evidence

Every decision logged to Splunk and turned into an Article 21(2)(d) supply-chain note.

Secrets safe

Env-only, masked in logs. Air-gapped demo with zero network calls.

SupplyGuard earns trust the way a security engineer does: **transparent decisions, an auditable trail, a gate on anything that halts a pipeline.**

YOUR SUPPLY CHAIN, SECURED

SupplyGuard

Every commit. Every dependency. Every build. In Splunk.

HEC

SPL

MCP Server

Hosted Models

Dashboard Studio

NIS2

github.com/manojmallick/supplyguard